Authentication Exercise (ไฟล์ login.php)

TODO 1 : เตรียมคำสั่ง SQL แบบ prepared statement

```php
// TODO 1: Query a single user by email using a prepared statement.
$sql = 'SELECT id, profile_id, password_hash FROM users WHERE email = ? LIMIT 1';
$stmt = mysqli_prepare($conn, $sql);
```

TODO 2 : ใส่ค่า, รัน, อ่านผลลัพธ์

```php
// TODO 2: Use mysqli_stmt_bind_param / execute / bind_result / fetch.
mysqli_stmt_bind_param($stmt, 's', $email);
mysqli_stmt_execute($stmt);
mysqli_stmt_bind_result($stmt, $uid, $pid, $hash);
$found = mysqli_stmt_fetch($stmt);
mysqli_stmt_close($stmt);
```

TODO 3 : ตรวจรหัสผ่านด้วย password_verify

```php
// TODO 3: Verify plaintext password with password_verify($password, $hash).
if ($found && password_verify($password, $hash)) {
```

TODO 4 : สร้าง session ใหม่ + เก็บข้อมูลผู้ใช้

```php
// TODO 4: On success, regenerate session ID and set session values.
session_regenerate_id(true);
$_SESSION['user_id'] = (int)$uid;
$_SESSION['profile_id'] = (int)$pid;
$_SESSION['email'] = $email;
```

TODO 5: เปลี่ยนหน้า (Redirect) ไปยัง skills.php เพื่อให้ผู้ใช้เข้าสู่ระบบ

```php
// TODO 5: Redirect to skills.php and exit.
header('Location: skills.php');
exit;
}
$error = 'Invalid email or password.';
}
}
```

ไฟล์ logout.php

TODO 6: ขั้นตอนการล็อกเอาต์

```php
public_html > 69-database-main > logout.php
<?php
require 'auth.php';
if ($_SERVER['REQUEST_METHOD']==='POST') {
    // TODO 6: CSRF check, clear $_SESSION, expire session cookie,
    // session_destroy(), redirect to login.php, exit.
    check_auth_token();
    $_SESSION = [];
    if (ini_get('session.use_cookies')) {
        $p = session_get_cookie_params();
        setcookie(session_name(), '', time() - 42000, $p['path'], $p['domain'], $p['secure'], $p['httponly']);
    }
    session_destroy();
    header('Location: login.php?logged_out=1');
    exit;
}
?>
<!doctype html><html lang="th"><head><meta charset="utf-8"><meta name="viewport" content="width=device-width,initial-scale=1"><title>Logout</title>
```

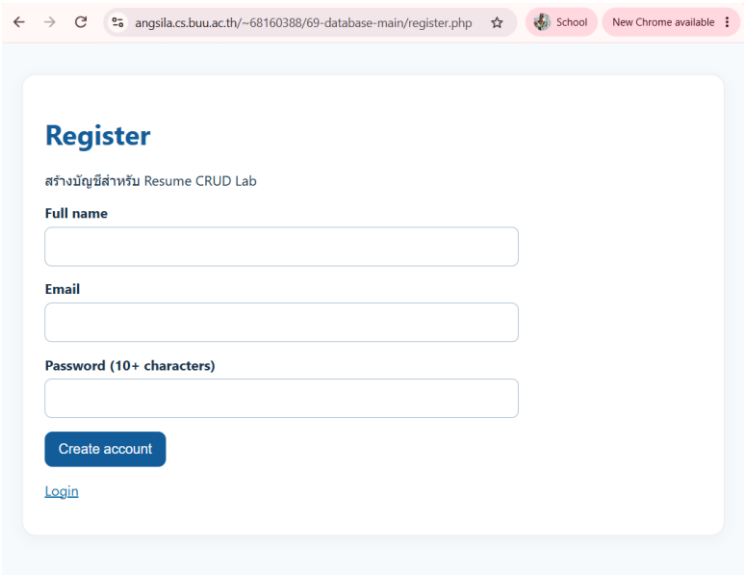
เมื่อผู้ใช้กดยืนยันล็อกเอาต์ ต้อง ตรวจว่าคำขอมาจากเราจริง ⟶ ล้างข้อมูลใน session → ลบ cookie → ทำลาย session → ไปหน้า login



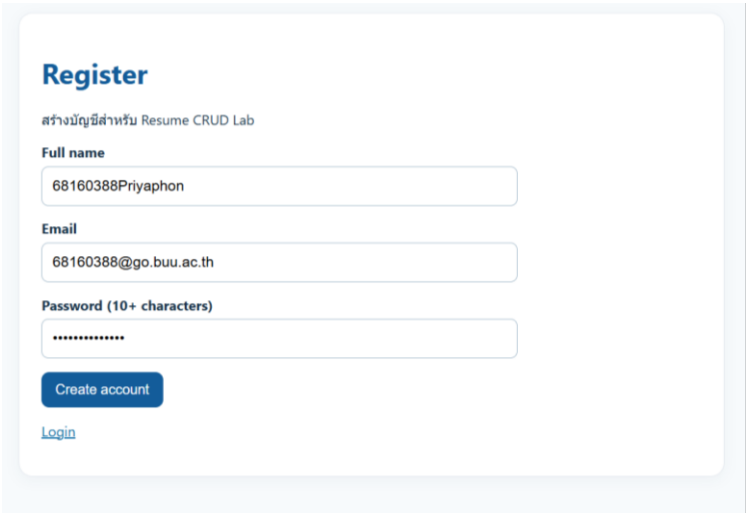
สตริง SQL injection ถูกบล็อกโดยเบราว์เซอร์ (ช่อง type=email) และต่อให้ข้ามเบราว์เซอร์ไปได้ ฝั่งเซิร์ฟเวอร์ยังมี filter_var(..., FILTER_VALIDATE_EMAIL) ตรวจรูปแบบอีเมลอีกชั้น และใช้ prepared statement (? + bind_param) ทำให้ข้อความที่ผู้ใช้กรอกถูกมองเป็นข้อมูล ไม่ใช่คำสั่ง SQL จึงข้ามการล็อกอินไม่ได้

1.ทดสอบสมัครสมาชิก

- หน้าสมัครสมาชิก

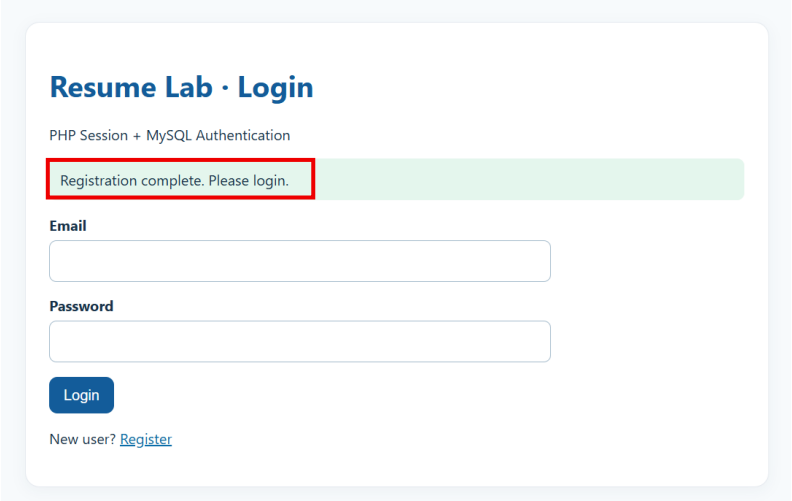


- ใส่ข้อมูล



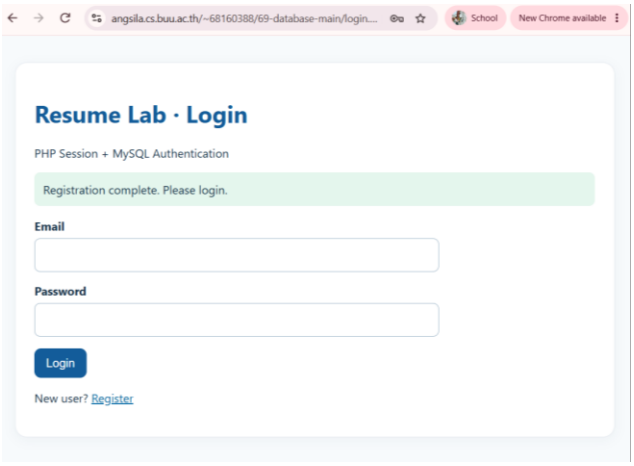
ผลการทดสอบ

- สมัครสมาชิกสำเร็จ

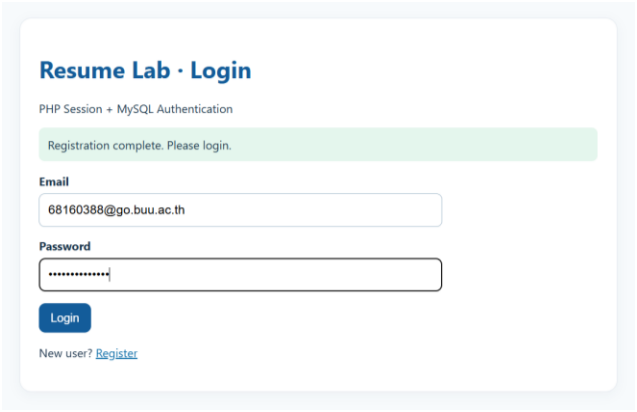


2.ทดสอบ **Login (สำเร็จ)**

- หน้า Login



- ใส่ข้อมูล



ผลการทดสอบ

- ใส่รหัสถูก Login (สำเร็จ)

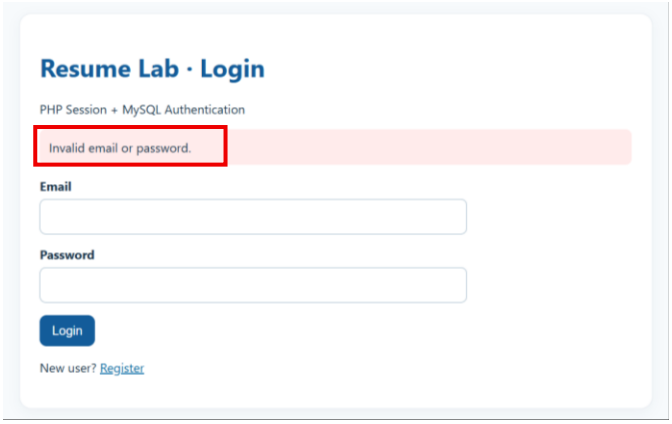


3.**Login (ล้มเหลว)**

- ใส่รหัสผิด Login (ไม่สำเร็จ)

  ขึ้นข้อความว่า

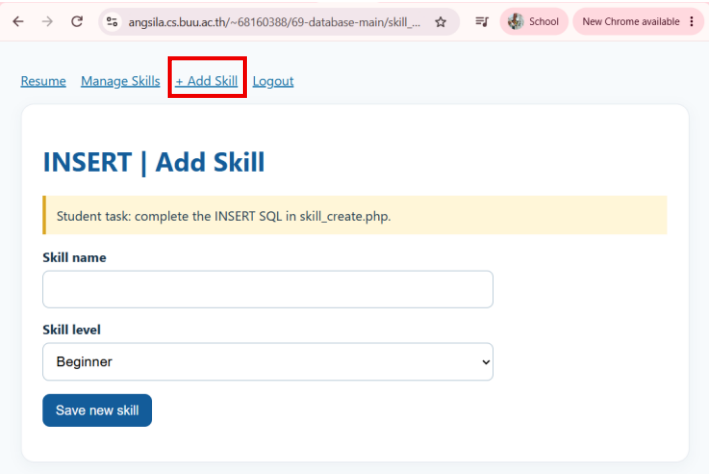
  “ Invalid email or password. ”



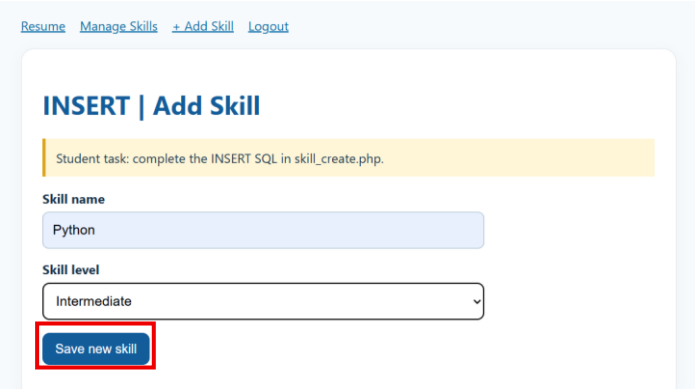
4.ทดสอบ **CRUD**

- การเพิ่มข้อมูล

- กด + Add Skill

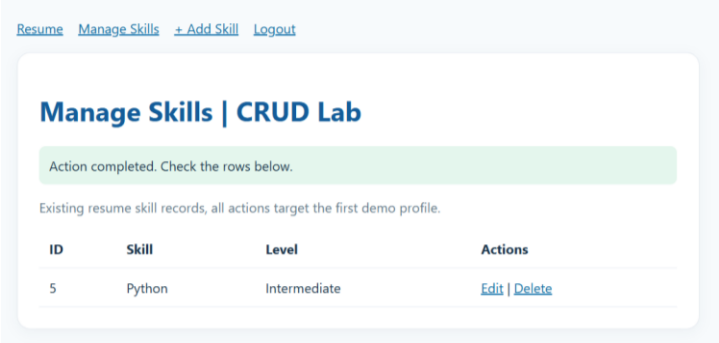


- ใส่ Skill ที่ต้องการเพิ่ม แล้วกด Save new Skill



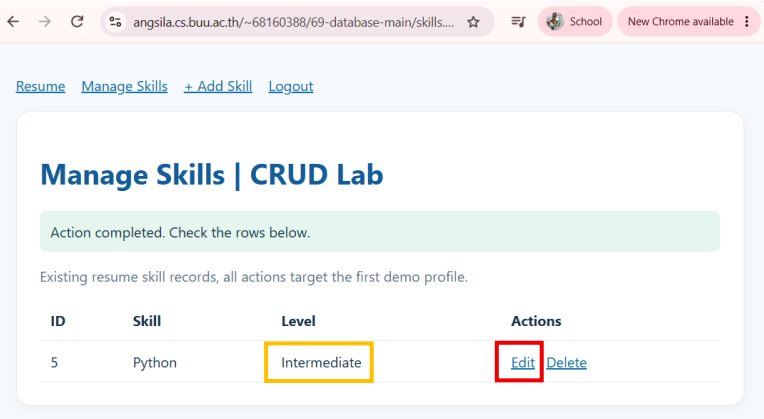
ผลการเพิ่มข้อมูล

- ข้อมูลถูกเพิ่มแล้ว

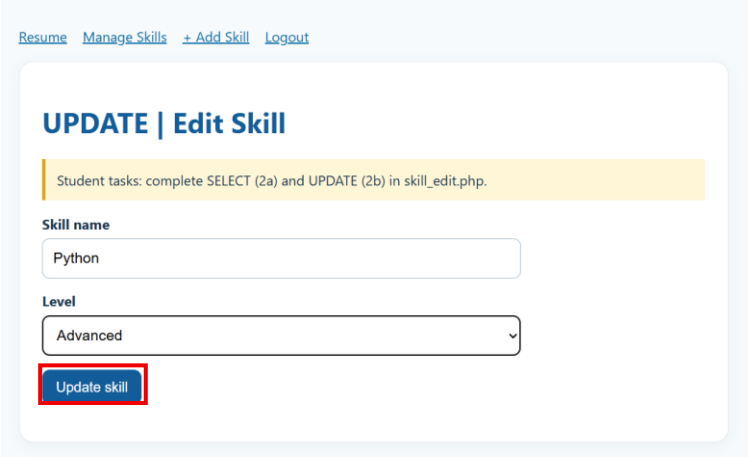


- การแก้ไขข้อมูล

- กด Edit

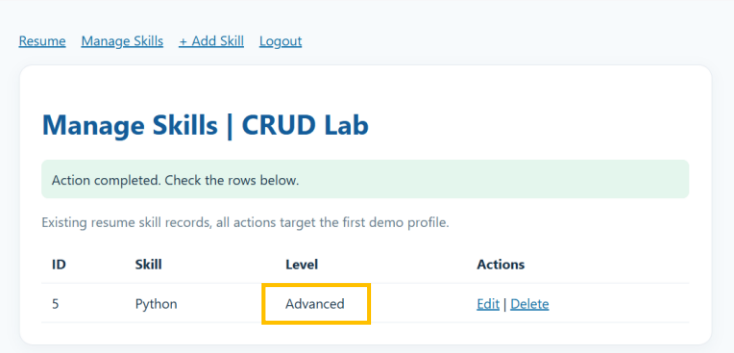


- ใส่ Skill ที่ต้องการแก้ไข แล้วกด Update Skill



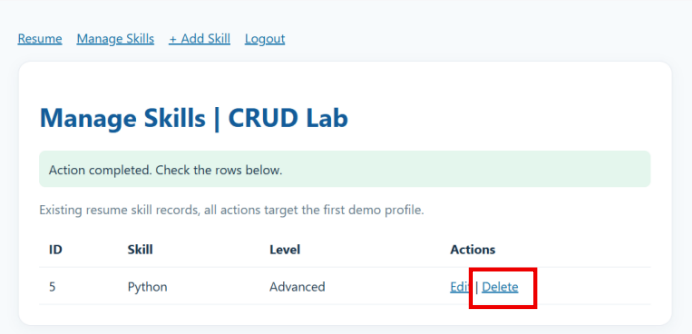
ผลการแก้ไขข้อมูล

- Level เปลี่ยนจาก Intermediate เป็น Advanced

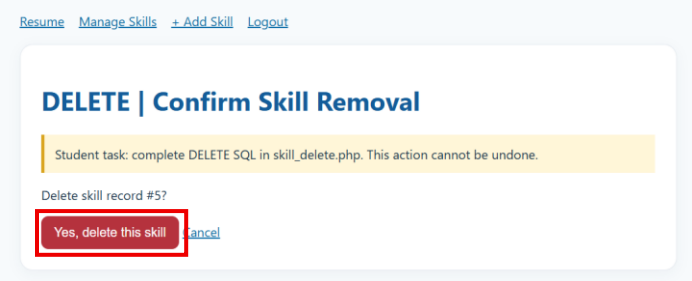


- การลบข้อมูล

- กด Delete



- กด Yes ยืนยันการลบ



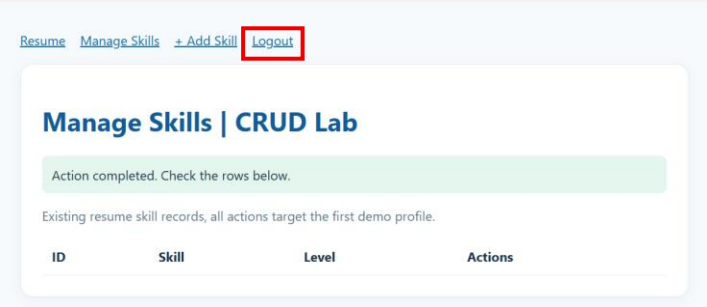
ผลการลบข้อมูล

- ข้อมูลถูกลบแล้ว

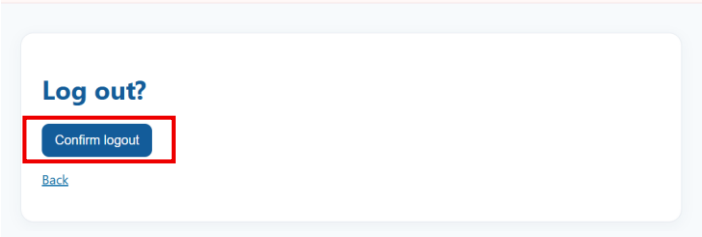


5.ทดสอบ **Logout**

- กด Logout

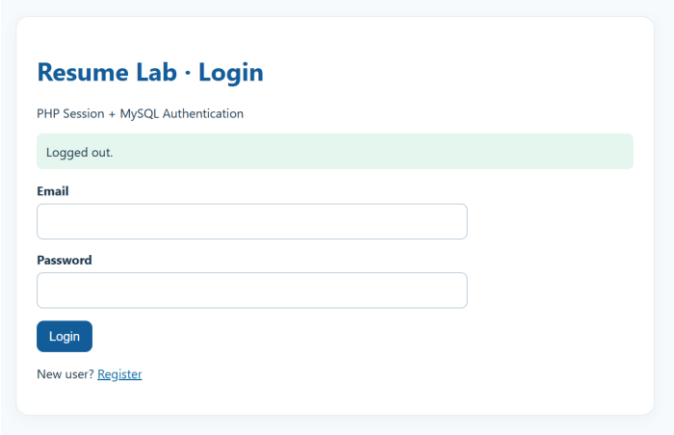


- กด Comfirm ยืนยันการ Logout



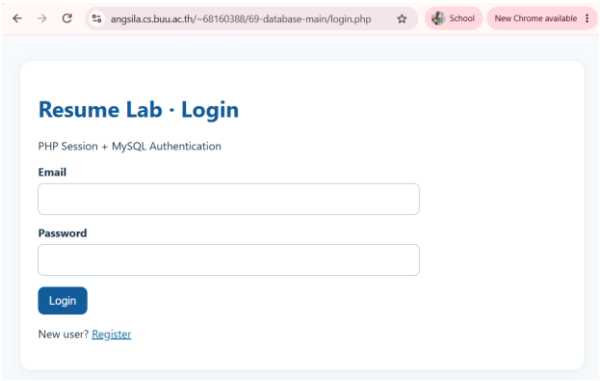
ผลการ Logout

- Logout แล้ว



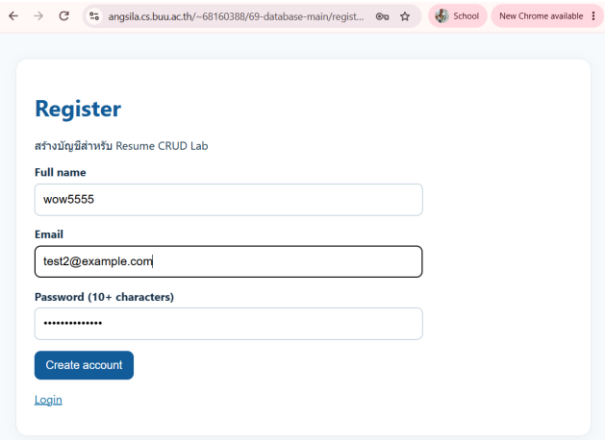
ทดสอบความปลอดภัย (เข้าหน้า **Private** ไม่ได้หลัง **Logout)**

ผลการ Logout



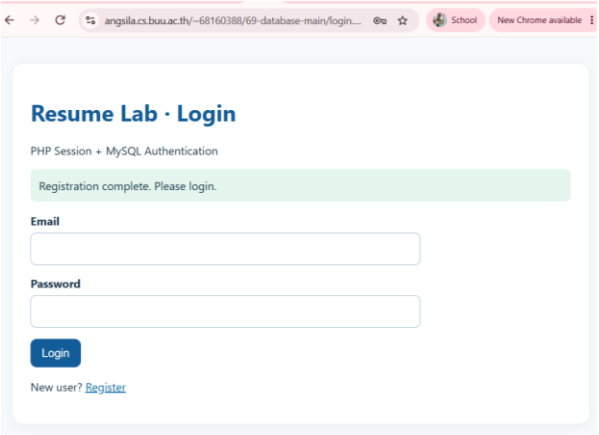
ทดสอบบัญชีที่ 2 จะไม่มี skill ขึ้นอยู่ เหมือนกับบัญชีแรก

- สมัครบัญชีที่ 2

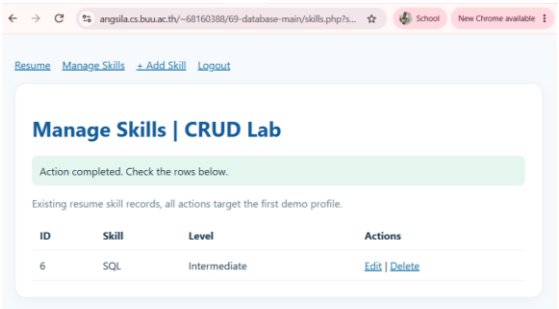


- ใส่ข้อมูล

- สมัครเรียบร้อย



- ลองเข้าระบบแล้วไม่เห็น skill ของบัญชีแรก



- บัญชีแรก

- บัญชีที่ 2



คำอธิบายเกี่ยวกับ Session และลำดับการทำงานของการเข้าสู่ระบบ / ออกจากระบบ (Login/Logout flow)

Ans ระบบยืนยันตัวตนใช้ PHP Session โดยเมื่อผู้ใช้เข้าสู่ระบบสำเร็จ จะใช้ session_regenerate_id(true) เพื่อป้องกัน Session Fixation และจัดเก็บ user_id, profile_id, และ email ลงใน $_SESSION เพื่อนำไปใช้จำกัดสิทธิ์การทำ CRUD ข้อมูลเฉพาะของตนเอง (Owner-scoped CRUD) ส่วนการ Logout จะกระทำผ่านคำขอแบบ POST ร่วมกับ CSRF Token เพื่อทำลาย Session และ Cookie ของระบบอย่างปลอดภัย